Phase 11: Secure Build & Static Security Analysis (SAST)

Course Code: 20CYS401 — Secure Software Engineering

Project: Online Book Review and Recommendation Platform

---

1. Static Application Security Testing (Bandit)

Bandit was executed across the complete Python codebase (`app/`).

Scan Metrics:

- **Total Lines of Code Scanned**: 1032 lines
- **Total Potential Issues Skipped**: 0
- **High Severity Vulnerabilities**: 0
- **Medium Severity Vulnerabilities**: 0
- **Low Severity Findings**: 1 (Mock secret string in `TestConfig` for local automated pytest executions)

```
Test results:
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password:
'test-secret-key-for-local-pytest-only'
Severity: Low Confidence: Medium
Location: app/config.py:34
```

---

2. Secret Scan Verification

Repository-wide scan for credentials, private keys, API keys, and environment tokens:

- **Target Extensions**: `.py`, `.env`, `.yml`, `.json`, `.txt`
- **Result**: Zero unauthorized production secrets committed.
- **Evidence Files**:
- `evidence/phase-11/bandit_scan.txt`
- `evidence/phase-11/secret_scan_report.txt`